

MODULE 25 · DOMAIN 3 - CONTINUOUS IMPROVEMENT FOR EXISTING SOLUTIONS

Automated Remediation

The goal is not fewer incidents. It is fewer incidents that need a human.

DOMAIN 3 of 4 EXAM WEIGHT 25% MODULE 25 of 44

Detection that ends in an email is not remediation. **Close the loop or accept the delay.**

The remediation loop

01

Detect

Config, GuardDuty,
CloudWatch or AWS
Health notices
something.

02

Route

EventBridge matches
the event and picks a
target.

03

Act

An SSM Automation
runbook or Lambda
function does the work.

04

Verify

The result is itself an
event you can alarm
on.

ON THE EXAM

The fourth step is the one teams skip. A remediation that fails silently is worse than none, because everyone believes it worked.

AWS Config remediation

- ◆ **A Config rule detects; an SSM Automation document fixes.** The rule names the runbook and passes the resource ID.
- ◆ **Three modes: automatic, manual, or manual with approval.** Retry count and interval are configurable.
- ◆ **Organisation Config rules** deploy the whole arrangement to every account from a delegated administrator.
- ◆ It is still **detective**. The resource existed in a bad state for some period, however short.

ON THE EXAM

AWS ships many remediation runbooks already, such as disabling public access on a security group. You rarely write one from scratch.

EventBridge as the nervous system

- ◆ **Almost everything emits events.** Config compliance changes, GuardDuty findings, SSM state changes, EC2 state changes.
- ◆ **AWS Health events** are the underused source: scheduled EC2 retirement, degraded services, certificate expiry, quota warnings.
- ◆ **A rule can target an SSM Automation runbook directly**, with no Lambda in between.
- ◆ **EventBridge Scheduler** covers the time-based half: run this runbook every night at two.

ON THE EXAM

AWS Health telling you an instance is scheduled for retirement is a fix you can fully automate. Most organisations still do it by hand.

Systems Manager Automation

- ◆ **Runbooks are documents** with steps, branching and error handling. AWS publishes hundreds of them already.
- ◆ **The Approval action pauses execution** until named principals approve, which puts a human in the loop without losing the automation.
- ◆ Runbooks can run **across accounts and Regions** in one execution, driven from a central account.
- ◆ **OpsCenter** collects issues as OpsItems and suggests the runbooks that remediate them.

ON THE EXAM

The Approval action is the answer whenever automation is wanted but a change must not happen unattended. It is not all-or-nothing.

Guardrails on your automation

- ◆ **Run rules in detection mode first.** Enabling auto-remediation blind is how you discover the deliberate exceptions painfully.
- ◆ **Alarm on remediation failure.** Match SSM automation status changes of Failed or TimedOut and route them to a topic.
- ◆ **Exclude what is intentionally non-compliant,** rather than letting people disable the rule entirely.
- ◆ Consider blast radius. A remediation that runs everywhere at once can turn one bad rule into an estate-wide outage.

ON THE EXAM

Automation applies your judgement at machine speed, including when your judgement was wrong. Test in detection mode first.

Preventive still beats detective

- ◆ **An SCP stops the API call.** Nothing bad ever exists, so there is nothing to remediate.
- ◆ **Config plus remediation fixes it afterwards.** The window may be seconds, and it is not zero.
- ◆ Use both. Preventive controls for the absolute rules, detective plus remediation for everything else.
- ◆ **Honest note:** Systems Manager Change Manager is closed to new customers. Existing customers continue as normal.

ON THE EXAM

Never and prevent are still preventive words, from module two. Remediation is the answer when the requirement says detect and correct.

Reading the scenario

THE SCENARIO SAYS

Detect and correct non-compliant resources

React to a scheduled instance retirement

Automate, but a human must approve

This must never happen at all

Remediation ran but nothing was fixed

Apply the same rule in every account

IT IS POINTING AT

Config rule with SSM remediation

AWS Health event to EventBridge

SSM Automation Approval action

An SCP, not remediation

Alarm on automation Failed or TimedOut

Organisation Config rules

ON THE EXAM

Detect and correct means remediation. Prevent means a policy. The verb in the requirement chooses the mechanism.

Meridian Freight finds that security groups allowing SSH from 0.0.0.0/0 keep appearing across 90 accounts, usually during troubleshooting and then forgotten. Security wants them closed within minutes, at any hour, with a record of what was changed.

Some are created legitimately during incidents and closed afterwards.

What should the solutions architect implement?

- ☐ A An organisation Config rule for restricted-ssh with automatic SSM remediation, deployed from a delegated administrator
- ☐ B A weekly report of open security groups sent to account owners
- ☐ C An SCP denying all security group modifications
- ☐ D A Lambda function scanning all accounts nightly

◆ PAUSE AND DECIDE

What should the solutions architect implement?

- A

Org Config rule with remediation
Detects on change, remediates within minutes at any hour, records everything in Config and CloudTrail, and deploys to all 90 accounts at once.
- B

Weekly report
Within minutes was the requirement. A weekly report is roughly ten thousand times too slow, and ends with a human.
- C

SCP denying changes
The scenario says some are created legitimately during incidents. Denying all changes breaks incident response.
- D

Nightly Lambda scan
Builds what Config already does, on a schedule that misses the requirement by hours, across 90 accounts you must reach.

THE SIGNAL

Some are legitimate is the planted detail. It rules out prevention and makes detect-and-correct the right shape.

AWS notifies the company that 40 EC2 instances are scheduled for retirement over the next fortnight because of degraded underlying hardware. An engineer currently reads each notification and schedules a stop and start manually, which takes about two days of effort each month.

The instances are EBS-backed and can be stopped and started at any convenient time.

What should the solutions architect implement?

- ☐ A An EventBridge rule on AWS Health events, targeting an SSM Automation runbook that stops and starts the instance
- ☐ B A CloudWatch alarm on instance status checks
- ☐ C Enable EC2 Auto Scaling so instances are replaced automatically
- ☐ D Subscribe the engineer to AWS Health notifications by email

◆ PAUSE AND DECIDE

What should the solutions architect implement?

- A

Health event to SSM runbook
Health emits the retirement event, EventBridge matches it, and the runbook stops and starts the instance onto healthy hardware. No human.
- B

Status check alarm
Fires once the instance has already failed. The whole value of a retirement notice is that it arrives beforehand.
- C

Auto Scaling
Would help for stateless fleets, and it is a large architectural change proposed to handle a maintenance notification.
- D

Email the engineer
Exactly the current process, which costs two days a month. It automates nothing.

THE SIGNAL

AWS Health is the underused event source. A retirement notice arrives in advance, which is what makes it fully automatable.

A team enabled automatic remediation on a Config rule requiring EBS volume encryption. The runbook detached and replaced volumes. It ran against a legacy database server whose unencrypted volume was a documented exception, causing a four-hour outage. Security still wants the rule enforced across the estate.

What should the solutions architect recommend?

- ☐ A Abandon automatic remediation and rely on reports
- ☐ B Run new rules in detection mode first, add explicit exclusions for documented exceptions, and use manual remediation with approval for destructive actions
- ☐ C Reduce the remediation retry count to one
- ☐ D Move the legacy server to a separate account with no Config rules

◆ PAUSE AND DECIDE

What should the solutions architect recommend?

- A

 Abandon automation
Overcorrects. One badly scoped rule does not mean remediation is wrong; it means this one was enabled without testing.
- B

 Detection mode, exclusions, approval
Keeps enforcement while fixing the three causes: no dry run, no exception handling, and a destructive action running unattended.
- C

 Fewer retries
The remediation succeeded. It did exactly what it was told, once. Retries were never involved.
- D

 Exempt account
Hides the exception by removing visibility of it, and creates an account where compliance is simply not checked.

THE SIGNAL

Read what actually failed. The automation worked perfectly; the scoping and the review process did not.

An audit finds 340 resources that a Config remediation rule should have fixed months ago. Investigation shows the remediation runbook has been failing since a permissions change, because its IAM role lost a required action. No alert was ever raised.

The compliance dashboard showed the rule as configured with automatic remediation throughout.

What should the solutions architect implement?

- ☐ A An EventBridge rule matching SSM Automation executions with status Failed or TimedOut, routed to SNS
- ☐ B Increase the remediation retry count
- ☐ C Review the Config dashboard weekly
- ☐ D Grant the remediation role AdministratorAccess to avoid permission gaps

◆ PAUSE AND DECIDE

What should the solutions architect implement?

- A** Alarm on failed automations
Closes the fourth step of the loop. A failing remediation becomes visible immediately rather than at the next audit.
- B** More retries
Retrying a call the role has no permission to make fails the same way, more often. The failure is deterministic.
- C** Weekly dashboard review
The dashboard showed remediation as configured throughout, which is precisely why nobody noticed. Reading it more often changes nothing.
- D** AdministratorAccess
Fixes this permission gap by removing least privilege from something that deletes and replaces production resources.

THE SIGNAL

This is the fourth step of the loop, skipped. Nobody verified that the automation was still working, and it failed for months.

A regulator requires that customer data buckets can never be made public, and asks the company to demonstrate that the control cannot be bypassed. The team proposes a Config rule with automatic remediation that removes public access within 30 seconds of detection. The company runs Control Tower across all accounts.

What should the solutions architect advise?

- ☐ A The proposal is sufficient; 30 seconds is fast enough
- ☐ B Use a preventive control so the change is refused, and keep the Config rule as detection and evidence
- ☐ C Reduce the remediation window to 10 seconds
- ☐ D Enable S3 Block Public Access and remove the Config rule

◆ PAUSE AND DECIDE

What should the solutions architect advise?

- A** 30 seconds is enough

Never and cannot be bypassed are absolute. A 30-second window is a 30-second window, however short it sounds.
- B** Preventive control, plus Config for evidence

The API call is refused so no public bucket ever exists, and the Config rule supplies the continuous evidence the regulator asked for.
- C** 10 seconds

Shrinks a window the requirement says must not exist. It is the same wrong answer with a smaller number.
- D** Block Public Access alone

The right preventive instinct, and removing the Config rule discards the evidence half of what the regulator asked for.

THE SIGNAL

Two requirements again: prevent it, and demonstrate it. Modules two and ten both said the same thing about that pair.

A platform team must apply a remediation that restarts a stuck agent on instances across 120 accounts and four Regions. Change policy requires that a named on-call engineer approves each execution before it runs, but the team does not want to abandon automation.

Executions must be recorded for audit.

What should the solutions architect recommend?

- ☐ A An SSM Automation runbook with an Approval action, run as a multi-account and multi-Region execution
- ☐ B A Lambda function that emails the on-call engineer with instructions
- ☐ C Fully automatic remediation, with the approval requirement waived
- ☐ D Run the fix manually in each of the 120 accounts

◆ PAUSE AND DECIDE

What should the solutions architect recommend?

- A

 Runbook with Approval action
The approval pauses the execution until the named principal approves, then it runs across all accounts and Regions, fully recorded.
- B

 Email with instructions
Turns automation back into a runbook a human types. Nothing is recorded and nothing is consistent.
- C

 Waive the approval
Solves the problem by ignoring the constraint. Change policy is an input, not an obstacle to route around.
- D

 Manual in 120 accounts
Satisfies approval by making the work enormous and inconsistent, with no reliable audit trail.

THE SIGNAL

Automation and human approval are not opposites. The Approval action is the specific feature that makes both true at once.

What to carry out of this module

- ◆ **Detect, route, act, verify.** The fourth step is the one teams skip, and it fails silently for months.
- ◆ **AWS Health to EventBridge to a runbook** is the underused pattern. Retirement notices arrive before the failure.
- ◆ **The Approval action** keeps automation while requiring a human. Automation is not all-or-nothing.
- ◆ **Prevent means a policy; detect and correct means remediation.** A short window is still a window.

ON THE EXAM

Run new rules in detection mode first. That is how you find the deliberate exceptions before they find you.